
개인정보보호암호기술

개인정보보호와 암호기술 개요

강원대학교 이세영



이번 시간에 다룰 내용

학습목표

01

개인정보의 개념과 특성을 이해한다

02

정보보안의 목표(기밀성 · 무결성 · 가용성)와 위협 유형을 설명할 수 있다

03

개인정보 보호에 암호기술이 어떻게 적용되는지 파악한다

데이터 · 정보 · 개인정보

□ 데이터 (Data)

- 현실 세계에서 측정하고 수집한 사실이나 값
 - 어떤 의미나 목적을 포함하지 않은, 가공되지 않은 원시 값
- 데이터의 특징
 - 기호화 · 숫자화 : 컴퓨터 프로그램으로 운용할 수 있는 형태
 - 존재적 특성 : 객관적 사실(Fact)을 그대로 나타냄
 - 당위적 특성 : 추론이나 예측을 위한 근거(Basis) 역할을 수행

오늘의 관측 값

기온 : 22 °C

습도 : 60 %

강수량 : 0 mm

미세먼지 : 20 $\mu\text{g}/\text{m}^3$

숫자 그 자체 —
아직 아무 판단도 담겨 있지 않음

데이터는 보호의 "대상"이 되는 가장 작은 단위이며,
암호기술이 직접 다루는 것도 결국 이 데이터이다

데이터 · 정보 · 개인정보

□ 정보 (Information)

■ 어떠한 목적이나 의도에 맞게 가공된 데이터

- 데이터를 분석 · 해석 · 재구성하여 의미 있는 형태로 변환한 결과

■ 정보의 특징

- 해석과 문맥 : 데이터가 특정 문맥에서 유의미한 지식으로 변환된 것
- 의사결정의 기초 : 단순한 사실이 아니라 의사결정에 활용되는 재료
- 가치와 목적성 : 사용 목적에 따라 그 가치가 결정됨

해석된 결과

오늘 날씨는 선선하고 쾌적하며,
강수량이 없어 맑을 것으로
예상됩니다.
대기질도 양호하여
야외 활동하기에 좋은 날씨입니다.

동일한 값이지만 "판단"이
더해져 가치를 가짐

정보보안은 데이터보안을 포괄하는 더 넓은 개념 —
데이터뿐 아니라 그 맥락 · 지식 · 문서 · 오프라인 자료까지 보호 대상

데이터 · 정보 · 개인정보

□ 데이터가 개인정보가 되는 순간



- 개인정보는 "특정 개인과 연결된 정보"라는 점에서 일반 정보와 구분됨
 - 그 자체로는 무의미한 값도 다른 정보와 결합하면 개인정보가 될 수 있음
- 따라서 보호 여부는 데이터의 형식이 아니라 식별 가능성으로 판단
 - 같은 값이라도 결합 가능한 정보가 무엇이냐에 따라 판단이 달라짐

보호해야 할 것은 "값"이 아니라 "값과 사람 사이의 연결"이다

개인정보의 법적 정의

□ 개인정보 보호법 제2조 제1호

"개인정보"란 살아 있는 개인에 관한 정보로서 다음 각 목의 어느 하나에 해당하는 정보를 말한다.

가. 성명, 주민등록번호 및 영상 등을 통하여 개인을 알아볼 수 있는 정보

나. 해당 정보만으로는 특정 개인을 알아볼 수 없더라도 다른 정보와 쉽게 결합하여 알아볼 수 있는 정보.
이 경우 쉽게 결합할 수 있는지 여부는 다른 정보의 입수 가능성 등 개인을 알아보는 데 소요되는
시간·비용·기술 등을 합리적으로 고려하여야 한다.

다. 가목 또는 나목을 가명처리함으로써 원래의 상태로 복원하기 위한 추가 정보의 사용·결합 없이는
특정 개인을 알아볼 수 없는 정보 (= 가명정보)

□ 정의에서 읽어야 할 세 가지

- 「살아 있는」 개인 → 사망자 정보는 원칙적으로 개인정보가 아님 (유족 관련성은 별도 판단)
- 「개인에 관한」 정보 → 법인·단체의 정보는 개인정보가 아님
- 「쉽게 결합하여」 알아볼 수 있는 정보까지 포함 → 보호 범위가 넓게 설정됨

개인정보 판단의 3가지 기준

생존성

살아 있는 개인에 관한 정보인가?

- 사망자 정보는 원칙적 제외
- 태아 · 사망자 정보는 별도 검토
- 법인 · 단체 정보는 해당 없음

개인 관련성

특정 개인에 관한 정보인가?

- 신체 · 재산 · 사회적 지위 등
- 주관적 평가 · 판단 정보도 포함
- 통계값 · 집합 정보는 원칙적 제외

식별 가능성

특정 개인을 알아볼 수 있는가?

- 그 자체로 식별 가능 (직접 식별자)
- 결합으로 식별 가능 (간접 식별자)
- 결합의 용이성: 입수 가능성 · 시간 · 비용 · 기술 고려

세 가지 기준을 모두 충족하면 개인정보 → 개인정보 보호법의 적용을 받는다

개인정보의 유형

구분	세부 유형	예시
일반정보	식별 · 연락 정보	성명, 주민등록번호, 주소, 전화번호, 이메일, 생년월일, 성별
신체정보	의료 · 생체 정보	진료기록, 병력, 혈액형, 지문, 홍채, 얼굴, 유전정보, 키·몸무게
정신정보	기호 · 성향 정보	종교, 사상, 정치적 견해, 취미, 도서 대출 기록, 구매 이력
재산정보	금융 · 신용 정보	계좌번호, 카드번호, 소득, 부동산, 신용등급, 세금 납부 내역
사회정보	교육 · 근로 · 법적 정보	학력, 성적, 자격증, 직장, 인사평가, 범죄경력, 병역사항
기타정보	통신 · 위치 · 행태 정보	IP 주소, 쿠키, 접속 로그, GPS 위치, 통화 내역, 서비스 이용 기록

- 오늘날에는 IP 주소 · 쿠키 · 단말기 식별자 · 위치 정보 등 「행태정보」의 비중이 크게 증가
 - 직접 이름을 담고 있지 않아도 개인을 지속적으로 추적 · 식별할 수 있어 보호 필요성이 큼

민감정보와 고유식별정보

민감정보 (법 제23조)

- 사상 · 신념
- 노동조합 · 정당의 가입 · 탈퇴
- 정치적 견해
- 건강 · 성생활 등에 관한 정보
- 유전정보 · 범죄경력자료
- 생체인식정보 (지문 · 홍채 · 얼굴)
- 인종 · 민족에 관한 정보

고유식별정보 (법 제24조)

- 주민등록번호
- 여권번호
- 운전면허번호
- 외국인등록번호

※ 주민등록번호는 법령에 구체적 근거가 있는 경우 등을 제외하고는 정보주체의 동의를 받더라도 처리할 수 없음 (법 제24조의 2)

왜 별도로 구분하는가

구분	처리 요건	안전조치	유출 시 피해
일반 개인정보	수집 · 이용 동의	일반적 안전조치	보통
민감정보	별도 동의 또는 법령 근거	암호화 등 강화된 조치	차별 · 낙인 등 회복 불가
고유식별정보	별도 동의 또는 법령 근거	저장 · 전송 시 암호화 의무	명의도용 · 금융범죄 직결

개인정보는 왜 특별한가

회복 불가능성

한 번 유출되면 회수가 불가능하다

유출된 데이터는 복제·재배포되며 삭제 요청으로 되돌릴 수 없다

불변성

바꿀 수 없는 식별자가 많다

주민등록번호·지문·홍채는 비밀번호처럼 재발급하기 어렵다

결합 증폭성

조각을 모으면 위력이 커진다

단독으로는 무해한 정보도 결합하면 한 사람의 전체 프로필이 된다

지속성

오래 남아 반복 악용된다

수년 전 유출 데이터가 다크웹에서 계속 거래·재활용된다

비대칭성

정보주체는 통제하기 어렵다

어디에 어떻게 저장·이용되는지 개인이 확인할 방법이 제한적이다

사후 대응(사고 후 보상)보다 사전 예방(암호화 · 최소수집 · 접근통제)이 훨씬 중요한 이유

개인정보 침해와 위협

□ 개인정보 침해의 주요 유형

외부 공격

- 해킹 · 악성코드 감염
- SQL 인젝션 · 취약점 공격
- 피싱 · 사회공학 기법

내부자 유출

- 권한 있는 직원의 무단 반출
- 퇴사자 계정 미삭제
- 위탁업체 직원의 유출

관리 부주의

- 접근권한 설정 오류
- 보안 패치 미적용
- 저장매체 · 문서 분실

수집 · 이용 위반

- 동의 없는 수집 · 목적 외 이용
- 과도한 수집 (최소수집 위반)
- 보유기간 초과 보관

기술적 조치(암호화 · 접근통제)와 관리적 조치(권한관리 · 교육 · 점검)가 함께 갖추어져야 실효성이 있다

국내 주요 개인정보 유출 사고

연도	사고	규모(추정)	주요 원인 · 특징
2008	옥션 회원정보 유출	약 1,081만 명	중국발 해킹, 국내 대규모 유출 사고의 시발점
2011	네이트 · 싸이월드 유출	약 3,500만 명	개발자 PC 악성코드 감염 → 내부망 침투
2011	넥슨 게임 회원정보 유출	약 1,320만 명	백업 서버 해킹, 게임 계정 정보 대량 유출
2014	카드 3사 고객정보 유출	약 1억 건	위탁업체 직원의 내부자 유출, 대규모 재발급 사태
2016	인터파크 회원정보 유출	약 1,030만 명	표적 피싱 메일(APT) → 장기 잠복 후 반출
2023~ 현재	통신사 · 플랫폼 등 유출 사고	수십만 ~ 수천만 건	인증 · 접근통제 미흡, 반복적 재발

- 유출 규모가 인구 수를 넘어서는 수준 → 사실상 전 국민이 한 번 이상 노출된 상태
- 원인은 반복적 : 외부 해킹, 내부자 반출, 위탁 관리 미흡, 접근통제 부재
 - 「암호화되지 않은 상태로 저장」된 데이터가 유출 피해를 결정적으로 키움

해외 주요 개인정보 유출 사고

연도	사고	규모(추정)	시사점
2013	Yahoo 계정 정보 유출	약 30억 계정	취약한 해시(MD5) 사용 → 비밀번호 대량 복원
2017	Equifax 신용정보 유출	약 1.47억 명	알려진 웹 취약점 패치 미적용, 신용정보 전면 노출
2018	Facebook-Cambridge Analytica	약 8,700만 명	API를 통한 제3자 과다 수집, 목적 외 정치 광고 활용
2018	Marriott 예약 시스템 유출	약 3.4억 건	인수 기업 시스템의 장기 침해 미탐지, 여권번호 포함
2021	Facebook 이용자 정보 공개	약 5.33억 명	스크래핑으로 수집된 전화번호 대량 공개

□ 사고에서 반복되는 세 가지 실패

- 암호 알고리즘 선택 실패 — 안전성이 깨진 해시 · 암호 알고리즘의 계속 사용
- 기본 관리 실패 — 알려진 취약점 패치 미적용, 접근 권한 방치, 로그 미점검
- 설계 단계의 실패 — 필요 이상 수집, 제3자 제공 통제 부재, 목적 외 이용

유출 이후 : 2차 피해의 확산



대표적인 2차 피해

피해 유형	내용	악용되는 정보
보이스피싱·스미싱	실제 정보를 근거로 신뢰를 얻어 금전 편취	이름, 연락처, 거래 이력
계정 탈취(크리덴셜 스테핑)	유출된 아이디·비밀번호를 다른 사이트에 대입	이메일, 비밀번호(해시 포함)
명의도용·금융 범죄	타인 명의로 계좌 개설·대출·가입	주민등록번호, 신분증 사본
표적 공격·협박	민감정보를 근거로 한 협박·사회공학 공격	건강, 성향, 위치 이력

유출된 데이터는 사라지지 않고 재활용된다 → 사고 대응보다 예방과 암호화가 우선

개인정보 생명주기와 단계별 위협



단계별 보호 조치

단계	핵심 원칙	대표 보호 조치
수집	최소 수집 · 목적 명확화 · 동의	전송구간 암호화, 수집 항목 최소화, 동의 이력 관리
저장 · 관리	기밀성 확보 · 접근 최소화	저장 시 암호화, 비밀번호 일방향 해시, 접근권한 통제
이용 · 제공	목적 범위 내 이용 · 추적 가능성	가명처리, 접속기록 보관, 위탁 계약 · 점검
파기	지체 없는 · 복구 불가능한 파기	완전 삭제, 매체 폐기, 암호키 파기(크립토 셰딩)

개인정보는 한 시점이 아니라 전 생명주기에 걸쳐 보호되어야 하며, 각 단계마다 필요한 암호기술이 다르다

정보보안의 기본 개념

□ 정보보안 (Information Security)

- 정보를 여러 위협으로부터 보호하여 그 가치를 유지하는 활동
 - 정보의 전체 라이프사이클(생성 · 처리 · 저장 · 전송 · 폐기)에 걸쳐 적용
- 보호 대상의 범위
 - 디지털 데이터 : 파일, 데이터베이스, 로그, 통신 패킷
 - 비(非)디지털 정보 : 인쇄 문서, 구두 전달 내용, 업무 지식
- 보안을 구성하는 세 가지 축

기술적 보안

암호화, 접근통제, 방화벽, 침입탐지,
로그 분석 등

관리적 보안

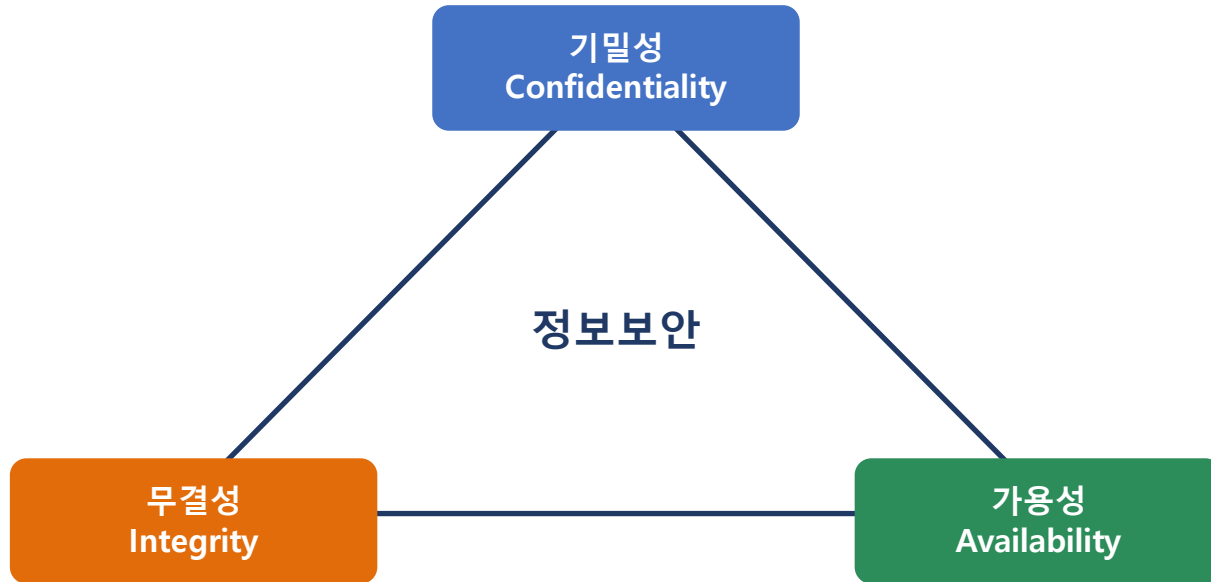
정책 · 지침 수립, 권한 관리, 교육,
정기점검 · 감사 등

물리적 보안

출입통제, 전산실 보호,
저장매체 · 문서 관리, 폐기 절차 등

암호기술은 「기술적 보안」의 핵심 수단이지만, 세 축이 함께 갖추어질 때만 실제 보호 효과가 나타난다

보안의 3대 요소 (CIA)



요소	정의	깨졌을 때	대표 기술
기밀성	인가된 사용자만 정보에 접근할 수 있도록 보장	정보 노출 · 도청	암호화, 접근통제
무결성	정보가 인가되지 않은 방법으로 변경되지 않도록 보장	위 · 변조, 신뢰 상실	해시, MAC, 전자서명
가용성	인가된 사용자가 필요할 때 정보를 사용할 수 있도록 보장	서비스 중단	이중화, 백업, DDoS 방어

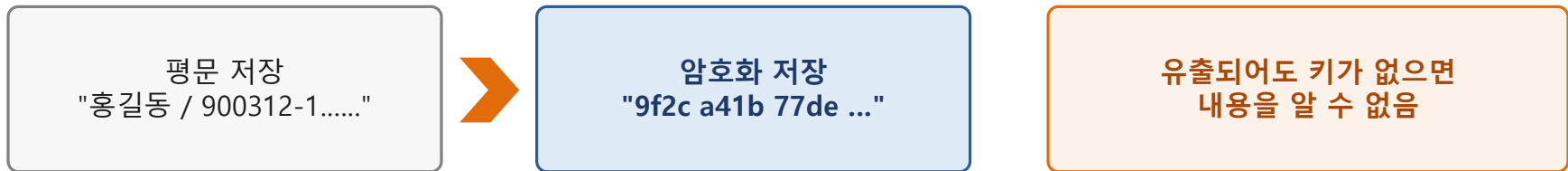
기밀성 (Confidentiality)

□ 정의

- 인가받지 않은 개인 · 시스템이 정보의 내용을 알 수 없도록 보장하는 성질
 - 데이터가 유출되더라도 「읽을 수 없는」 상태를 유지하는 것이 목표

□ 개인정보 보호에서의 의미

- 고유식별정보 · 비밀번호 · 생체인식정보는 저장 · 전송 시 암호화가 요구됨
- 접근권한을 업무상 필요한 최소 범위로 제한 (최소권한 원칙)



위협	설명	대응 기술
도청 (Eavesdropping)	네트워크를 오가는 데이터를 몰래 관찰	전송 구간 암호화 (TLS)
데이터베이스 탈취	저장된 데이터를 통째로 반출	저장 시 암호화, 키 분리 보관
권한 오남용	접근권한을 가진 자가 목적 외로 열람	최소권한, 접속기록 · 이상행위 탐지
트래픽 분석	내용이 아닌 통신 패턴에서 정보를 추론	패딩, 트래픽 은닉, 익명 통신

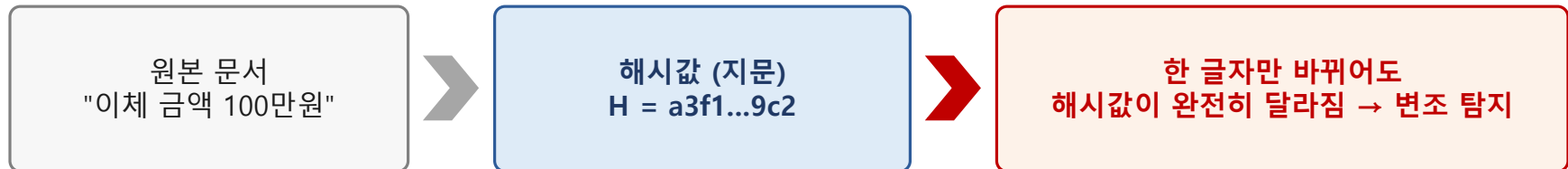
무결성 (Integrity)

□ 정의

- 정보가 인가되지 않은 방법으로 변경 · 삭제되지 않았음을 보장하는 성질
 - 「변경을 막는 것」보다 「변경 여부를 확인할 수 있는 것」이 실질적 목표

□ 개인정보 보호에서의 의미

- 개인정보의 정확성 · 최신성 유지는 정보주체의 권리와 직결됨
- 접속기록 · 로그의 무결성이 깨지면 사고의 원인 추적 자체가 불가능해짐



위협	설명	대응 기술
메시지 변조	전송 중인 데이터의 내용을 바꿔치기	해시 함수, 메시지 인증 코드(MAC)
데이터 위조	존재하지 않던 데이터를 만들어 삽입	전자서명, 인증서
재전송 (Replay)	정상 메시지를 가로챈 뒤 그대로 다시 전송	난스(nonce), 타임스탬프, 순서번호
로그 조작	침입 흔적을 지우기 위해 기록을 수정	로그 서명, 무결성 검증, 분리 보관

가용성 (Availability)

□ 정의

- 인가된 사용자가 필요한 시점에 정보와 서비스를 사용할 수 있도록 보장하는 성질
 - 보안이 지나치게 강화되어 정당한 사용자마저 접근하지 못하면 가용성 훼손

□ 개인정보 보호에서의 의미

- 정보주체의 열람 · 정정 · 삭제 요구는 서비스가 살아 있어야 행사 가능
- 암호화 키를 분실하면 데이터가 영구 복구 불가 → 키 관리는 가용성 문제이기도 함

위협	설명	대응 방안
서비스 거부 공격 (DoS · DDoS)	대량의 요청으로 시스템 자원을 고갈	트래픽 필터링, CDN, 자동 확장
랜섬웨어	데이터를 암호화하여 사용 불가 상태로 만듦	오프라인 백업, 복구 훈련, 접근통제
시스템 · 하드웨어 장애	서버 · 디스크 · 네트워크 고장	이중화, 클러스터링, 무정지 설계
재해 · 정전 · 화재	데이터센터 물리적 손상	재해복구(DR) 센터, 지리적 분산
키 분실 · 키 손상	복호화 키를 잃어 데이터 복구 불가	키 백업 · 에스크로, 키 관리 시스템

기밀성 · 무결성 · 가용성은 서로 상충할 수 있다 → 보안 설계는 세 요소 사이의 균형을 찾는 일

확장 보안 요소

인증 Authentication

통신 상대나 정보의 출처가 주장하는 바와 일치함을 확인하는 성질

- 사용자 인증 : 비밀번호, OTP, 생체인증
- 메시지 인증 : MAC, 전자서명
- 개체 인증 : 챌린지-응답 프로토콜

부인방지 Non-repudiation

어떤 행위를 한 주체가 나중에 그 사실을 부인할 수 없도록 하는 성질

- 송신 부인방지 : 보내지 않았다고 못 함
- 수신 부인방지 : 받지 않았다고 못 함
- 핵심 기술 : 전자서명 + 인증서

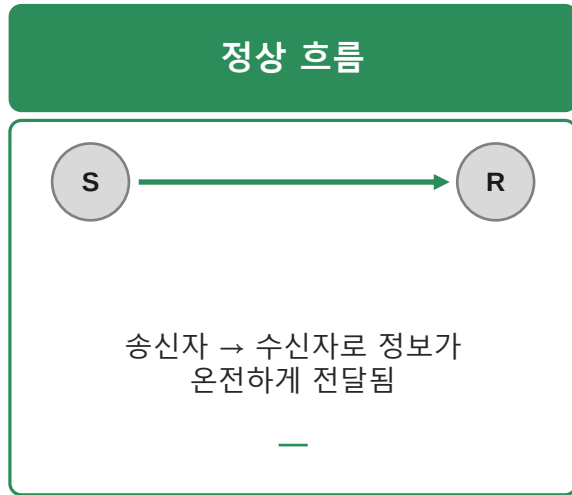
책임추적성 Accountability

시스템에서 일어난 행위를 특정 주체까지 되짚어 갈 수 있는 성질

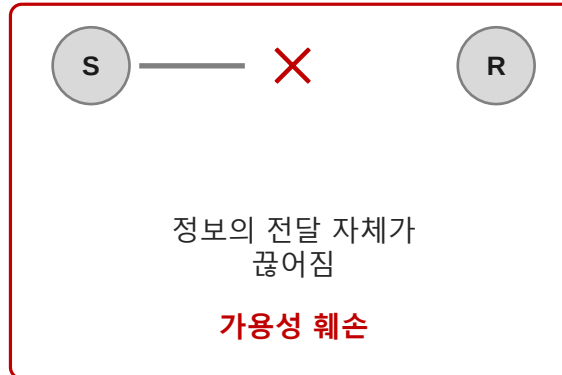
- 접속기록(로그) 보관 및 보호
- 계정 공유 금지 · 1인 1계정 원칙
- 개인정보 보호법상 접속기록 보관 의무

기밀성 · 무결성 · 가용성 + 인증 · 부인방지 · 책임추적성 = 실제 시스템이 요구하는 보안 요구사항의 집합

보안 위협의 4가지 유형



차단 Interruption



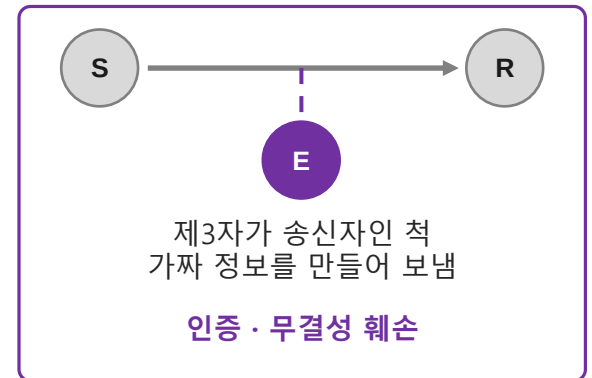
가로채기 Interception



변조 Modification



위조 Fabrication



차단 → 가용성 / 가로채기 → 기밀성 / 변조 → 무결성 / 위조 → 인증 · 무결성 (위협과 보안 목표는 1:1로 대응)

소극적 공격과 적극적 공격

구분	소극적 공격 (Passive Attack)	적극적 공격 (Active Attack)
행위	정보를 관찰 · 수집하기만 함	정보를 변경 · 삭제 · 생성함
대표 유형	도청(스니핑), 트래픽 분석	신분위장, 재전송, 메시지 변조, 서비스 거부
침해 대상	기밀성	무결성 · 가용성 · 인증
탐지	매우 어려움 (흔적이 남지 않음)	상대적으로 쉬움 (변화가 관찰됨)
예방	가능 (암호화로 무력화)	완전 예방 어려움
대응 전략	예방에 중점 — 암호화	탐지 · 복구에 중점 — 인증 · 로그 · 백업

□ 왜 이 구분이 중요한가

- 소극적 공격은 「막을 수 없지만 무의미하게 만들 수 있다」
 - 도청 자체를 차단하기는 어려우나, 암호화하면 엿들어도 의미를 알 수 없음
- 적극적 공격은 「완전히 막을 수 없으므로 빠르게 발견하고 되돌려야 한다」
 - 무결성 검증, 접속기록, 백업 · 복구 체계가 함께 필요

개인정보보호와 암호기술

□ 왜 암호기술이 필요한가

1

경계 방어만으로는 부족하다

방화벽 · 접근통제는 「들어오지 못하게」 막지만, 뚫린 뒤에는 아무것도 지켜 주지 못한다

2

암호화는 최후의 방어선이다

데이터가 유출되어도 키가 없으면 읽을 수 없다 → 사고를 「피해」로 만들지 않는다

3

법이 요구하는 의무이다

고유식별정보 · 비밀번호 · 생체인식정보의 암호화는 법령상 안전조치 의무

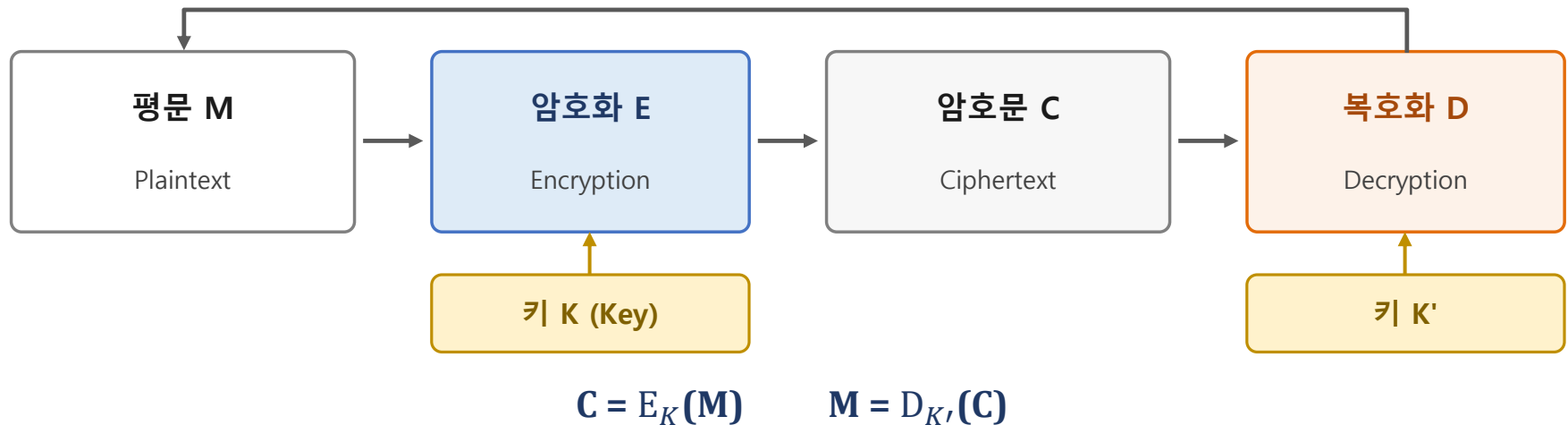
4

활용과 보호를 동시에 가능하게 한다

가명처리 · 동형암호 등은 데이터를 쓰면서도 개인을 드러내지 않게 해 준다

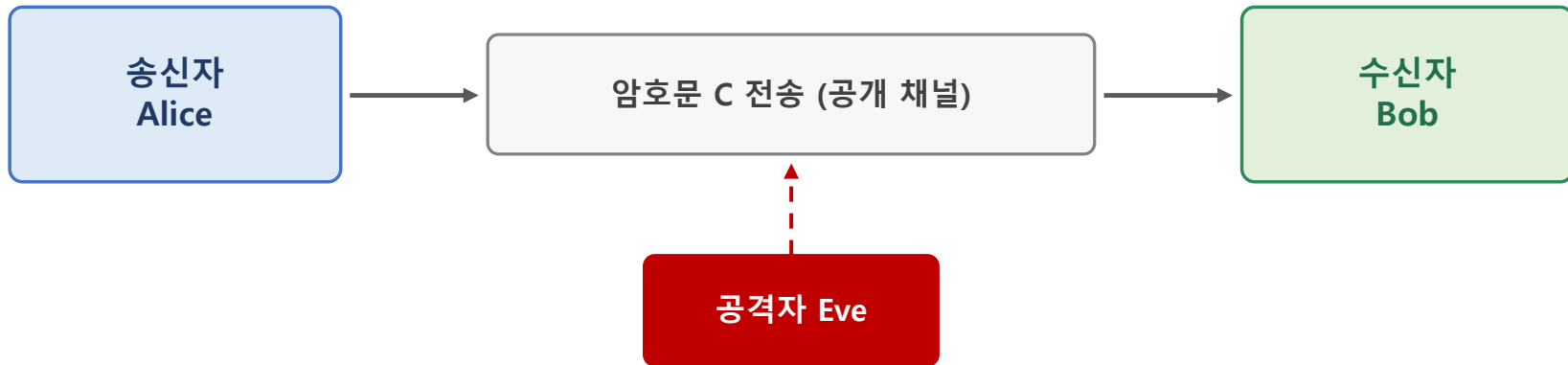
「침해는 언젠가 일어난다」를 전제로 설계하는 것 = 암호기술을 개인정보 보호의 기본값으로 두는 것

암호의 기본 용어와 모델



용어	설명	개인정보 보호에서의 예
평문 (Plaintext)	보호하려는 원래의 데이터	주민등록번호, 계좌번호, 진료기록
암호문 (Ciphertext)	암호화되어 의미를 알 수 없게 된 데이터	DB에 저장된 암호화 컬럼 값
암호화 (Encryption)	키를 이용해 평문을 암호문으로 바꾸는 과정	DB 저장 시 · 네트워크 전송 시 수행
복호화 (Decryption)	키를 이용해 암호문을 평문으로 되돌리는 과정	권한 있는 업무 처리 시에만 수행
키 (Key)	암호화 · 복호화를 제어하는 비밀 값	별도의 안전한 저장소에서 분리 관리

암호 시스템과 공격자 모델



□ 케르크호프스의 원리 (Kerckhoffs' Principle)

- 암호 시스템의 안전성은 알고리즘의 비밀이 아니라 오직 「키의 비밀」에 의존해야 한다
 - 알고리즘은 공개되어 검증받는 편이 오히려 안전 (공개 검증 → 취약점 조기 발견)
 - "보안을 숨김으로 달성한다(security by obscurity)"는 접근은 실패한다

□ 공격자에 대한 가정

- 알고리즘의 전체 구조를 알고 있다고 가정
- 통신 채널을 관찰 · 변조할 수 있다고 가정
- 현실적으로 충분한 계산 자원을 가지고 있다고 가정 → 「계산적으로 불가능」하게 만드는 것이 목표

암호기술의 분류

대칭키 암호

암호화 키 = 복호화 키

- AES, ARIA, SEED, ChaCha20
- 빠르고 대용량 처리에 적합
- 키 공유 · 관리가 어려움

공개키 암호

공개키로 암호화, 개인키로 복호화

- RSA, ECC, ElGamal
- 키 공유 문제를 해결
- 대칭키보다 매우 느림

해시 함수

임의 길이 → 고정 길이 (일방향)

- SHA-256, SHA-3, LSH
- 역산 불가 · 충돌 저항성
- 무결성 · 비밀번호 저장

메시지 인증 코드

해시 + 비밀키

- HMAC, CMAC, GMAC
- 무결성 + 송신자 인증
- 부인방지는 제공하지 못함

전자서명

개인키로 서명, 공개키로 검증

- RSA-PSS, ECDSA, EdDSA
- 무결성 + 인증 + 부인방지
- 인증서(PKI)와 함께 사용

보안 목표와 암호기술의 대응

보안 목표	대칭키 암호	공개키 암호	해시 함수	MAC	전자서명
기밀성	●	●	—	—	—
무결성	—	—	●	●	●
인증	△	△	—	●	●
부인방지	—	—	—	—	●
키 교환	—	●	—	—	—

● 제공 △ 부분적 · 조건부 제공 — 제공하지 않음

□ 읽는 법

- 하나의 기술이 모든 보안 목표를 제공하지는 않는다 → 조합해서 사용
 - 예) 기밀성 + 무결성 + 인증이 동시에 필요하면 「대칭키 암호 + MAC」 또는 인증암호(AEAD) 사용
 - 예) 기밀성 + 부인방지가 필요하면 「공개키 암호 + 전자서명」 조합
- 부인방지는 오직 전자서명만 제공 → 서명자만이 개인키를 가지고 있기 때문

개인정보 생명주기와 암호기술 적용

단계	보호 요구	적용 암호기술	구체적 예
수집	전송 중 노출 방지	공개키 암호 + 대칭키 암호 (TLS)	회원가입 · 결제 화면의 HTTPS 통신
저장 · 관리	유출 시 판독 불가	대칭키 암호 (AES 등)	주민등록번호 · 계좌번호 컬럼 암호화
저장 · 관리	복호화 자체가 불필요	해시 함수 + 솔트	비밀번호 일방향 저장 (복원 불가)
이용 · 제공	변조 · 위조 탐지	MAC, 전자서명	API 응답 서명, 전자문서 서명
이용 · 제공	식별 없이 분석	가명처리, 동형암호, MPC	통계 · AI 학습용 데이터 활용
이용 · 제공	행위 추적 가능성	해시 · 서명 기반 로그 무결성	접속기록 위 · 변조 방지
파기	복구 불가능한 삭제	암호키 파기 (Crypto-shredding)	키만 안전 파기 → 데이터 복원 불가

동일한 데이터라도 「어느 단계에 있느냐」에 따라 필요한 암호기술이 달라진다

- 비밀번호는 「암호화」가 아니라 「해시」로 저장
— 서비스 제공자조차 원래 값을 알 필요가 없기 때문

암호화의 법 · 제도적 근거

□ 개인정보 보호법 제29조 (안전조치의무)

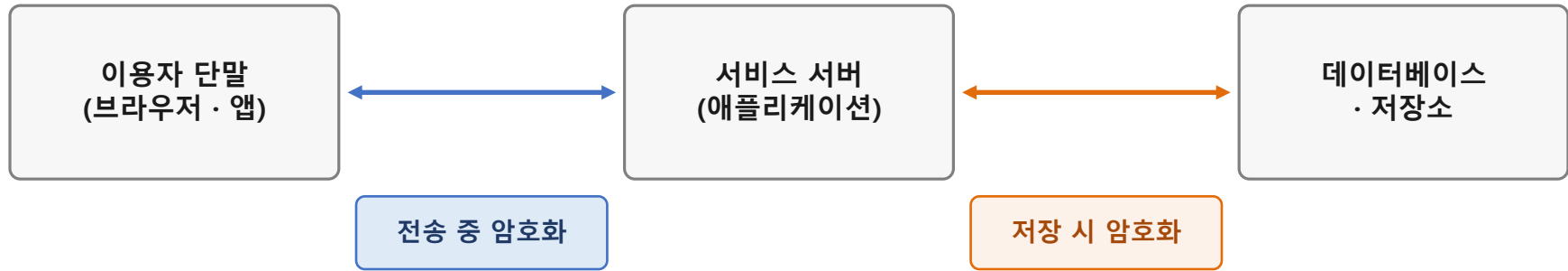
개인정보처리자는 개인정보가 분실 · 도난 · 유출 · 위조 · 변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록의 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다.

□ 개인정보의 안전성 확보조치 기준 — 암호화 요구 사항

구분	대상 정보	요구되는 조치
전송 시	고유식별정보, 비밀번호, 생체인식정보	정보통신망 송신 · 보조저장매체 전달 시 암호화
저장 시	비밀번호	일방향 암호화(해시)하여 저장 — 복호화 불가
저장 시	고유식별정보, 생체인식정보	암호화하여 저장
저장 시	인터넷 구간 · DMZ에 저장하는 고유식별정보	반드시 암호화하여 저장
키 관리	암호화에 사용되는 키	안전한 보관 절차 수립 · 시행 (데이터와 분리)

- 암호화는 「권장」이 아니라 「의무」 — 미이행 시 사고가 없어도 제재 대상이 될 수 있음
- 알고리즘은 안전성이 인정된 표준(AES, SHA-2 등) 사용 — 취약해진 MD5 · SHA-1 · DES 사용은 미이행으로 평가

암호화는 어디에 적용되는가



구분	전송 중 암호화 (in transit)	저장 시 암호화 (at rest)
보호 대상 위협	도청 · 중간자 공격 · 변조	DB 탈취 · 백업 유출 · 매체 분실
대표 기술	TLS (공개키로 키 교환 → 대칭키로 통신)	AES 등 대칭키 암호, 컬럼 · 파일 · 디스크 암호화
적용 지점	단말 ↔ 서버, 서버 ↔ 서버	DB 컬럼, 파일 시스템, 백업 매체
한계	서버에 도착한 뒤에는 평문이 됨	메모리에서 처리할 때는 평문이 됨

- 두 지점을 모두 암호화해도 「처리 중(in use)」 구간은 여전히 평문 → 남는 위험
 - 이 빈틈을 메우려는 시도가 동형암호 · 안전한 다자간 연산 · 신뢰실행환경(TEE)

개인정보보호 강화기술 (PET)

□ 기존 암호화의 딜레마

- 암호화하면 안전하지만 「쓸 수 없고」, 복호화하면 쓸 수 있지만 「위험하다」
 - 데이터 활용(통계 · AI 학습 · 연구)과 개인정보 보호가 충돌하는 지점

□ 식별성을 낮추는 접근 : 가명처리와 익명처리

구분	원본 정보	가명정보	익명정보
식별 가능성	직접 식별 가능	추가 정보 있으면 식별 가능	복원 불가 · 식별 불가
법적 지위	개인정보	개인정보 (규제 완화 적용)	개인정보 아님
활용 범위	동의받은 목적 내	통계 · 과학적 연구 · 공익적 기록보존	제한 없음
데이터 유용성	높음	중간	낮음
예시	홍길동, 900312-1.....	A0173, 1990년생, 남	1990년대생 남성 1,240명

보호 수준을 높일수록 데이터 유용성은 떨어진다 → 「재식별 위험」과 「유용성」의 균형 문제

개인정보를 지키는 최신 암호기술

동형암호 Homomorphic Encryption

암호문 상태로 연산이 가능한 암호

$\text{Enc}(a) \oplus \text{Enc}(b) = \text{Enc}(a+b)$
복호화 없이 통계 · 학습 수행

안전한 다자간 연산 MPC

각자 데이터를 공개하지 않고 함께 계산

여러 병원이 원본을 공유하지 않고
공동 통계 산출

영지식증명 Zero-Knowledge Proof

정보를 드러내지 않고 사실만 증명

생년월일을 밝히지 않고
"19세 이상"만 증명

차분 프라이버시 Differential Privacy

결과에 통제된 잡음을 더해 개인 기여를 은닉

통계 결과로부터 특정 개인의
포함 여부를 알 수 없게 함

공통 목표 : 「데이터를 쓰면서도 개인을 드러내지 않는다」 — 보호와 활용의 양립

핵심 정리

개인정보

살아 있는 개인에 관한 정보로서 그 자체 또는 다른 정보와 쉽게 결합하여 특정 개인을 알아 볼 수 있는 정보 — 판단 기준은 생존성 · 개인 관련성 · 식별 가능성

특별 보호 대상

민감정보(사상 · 건강 · 생체 등)와 고유식별정보(주민등록번호 · 여권번호 · 운전면허번호 · 외국인등록번호)는 별도 동의와 강화된 안전조치 필요

보안 3대 요소

기밀성(인가된 자만 접근) · 무결성(무단 변경 방지) · 가용성(필요할 때 사용)
— 서로 상충하므로 균형이 필요

확장 보안 요소

인증(출처 확인) · 부인방지(행위 부인 불가) · 책임추적성(행위 주체 추적)

위협의 4유형

차단→가용성, 가로채기→기밀성, 변조→무결성, 위조→인증 · 무결성

핵심 정리

암호의 기본 모델

$C = E_K(M)$, $M = D_{K'}(C)$
 — 안전성은 알고리즘이 아니라 「키의 비밀」에 의존한다 (케르크호프스의 원리)

기술과 목표의 대응

기밀성 → 대칭키 · 공개키 암호 / 무결성 → 해시 · MAC · 전자서명 /
 인증 → MAC · 전자서명 / 부인방지 → 전자서명만

생명주기별 적용

수집(전송 암호화) → 저장 · 관리(대칭키 암호 · 비밀번호 해시)
 → 이용 · 제공(서명 · 가명처리) → 파기(암호키 파기)

법적 의무

고유식별정보 · 생체인식정보는 암호화 저장,
 비밀번호는 일방향 해시 저장,
 키는 데이터와 분리 관리

보호와 활용의 양립

가명 · 익명처리, 동형암호, 안전한 다자간 연산, 영지식증명, 차분 프라이버시



hank You

E-mail: seyoung@kangwon.ac.kr